CYBERSECURITY ENGINEERING

Enterprise Zero Trust Security Architecture

HL-CYB-001 | Four-week practical assignment | T6 baseline, 2026-11-06

Build an isolated lab that lets people do their assigned work, denies unnecessary access and produces evidence a reviewer can understand. **Implementation is PLANNED; operational controls are NOT TESTED. Owner user acceptance testing (UAT) is PENDING.**

Assignment contents

1. Project Overview 1

2. Project Objectives 1

3. Project Scope 2

4. Technologies and Resources 2

5. Project Requirements 2

6. Expected Deliverables 3

7. Implementation Approach 3

8. Success Criteria 4

9. References 4

1. Project Overview

A synthetic organization, Purple Eye, needs an analyst to read reports and an engineer to read restricted maintenance instructions. An unassigned user must receive neither permission. A separate administrator manages the lab. Demonstrate these decisions locally and give one approved remote user access to one application. Use invented people and business data.

Zero Trust means checking identity and permission for each resource. Network membership alone must not grant access. The outcome is a working lab with measured results, a successful restore and an honest account of its limits.

2. Project Objectives

Build three isolated zones; prove six role cases and revocation; verify HTTPS, remote access, logs and one automation; restore one backup and present sanitized evidence.

3. Project Scope

Use one Proxmox host, one virtual OPNsense firewall, one Windows Server, one Windows endpoint and one Linux application server. The zones are **Management, Corporate and Restricted**. Create three synthetic standard users, three role groups and one separate privileged administrator. Use one simple certificate authority (CA), one HTTPS application certificate and **Tailscale only**, in a separate lab environment.

Collect two or three log sources, record five representative security events, investigate one denial, automate one useful operation and restore one backup. High availability, clustering, additional zones/VMs, dual remote providers, two-tier PKI and enterprise timing/retention targets are excluded.

Keep home and production outside the lab. No corporate identities, trust, synchronization, credentials, Microsoft 365, PE-DAP, customer data, website testing or hosting integration. Start offline; online dependencies require an approved independent isolation boundary. Never probe protected networks; use configuration inspection, passive observation and lab-owned mock targets.

4. Technologies and Resources

Use Proxmox VE, OPNsense, supported Windows Server with Active Directory (AD), DNS and Group Policy, Windows, Linux/Apache HTTPS, OpenSSL, Tailscale and PowerShell or Python. The architecture defines allocations; the guide gives procedures.

Hardware status, owner-reported 2026-11-06: Existing equipment includes the Dell Precision 5820 (W-2125, 80 GB RAM, 512 GB SSD), Lenovo laptop, HP desktop, test laptops and Google Wifi; thermal paste is available. Suitability is unverified. **Ordered:** Xeon W-2145, Samsung 1 TB SSD, Sabrent PCIe adapter, Intel I350-T4 NIC, GL.iNet Beryl AX and TP-Link managed switch, per the latest owner procurement plan. **Delivered:** unconfirmed; expected November 7 for non-CPU items and November 12, 2026 for the CPU. **Installed:** no T6 installation evidence or assumption that lab software exists. **Validated:** no hardware-readiness or operational-lab evidence.

Do not reorder these items or expand the lab to use them all. Before installation confirm delivery, physically inspect parts, verify compatibility, inventory existing data/services, establish backup/recovery and obtain exact owner approval for destructive changes. Preserve the original Windows disk and existing services. The four working weeks begin after readiness and approvals.

5. Project Requirements

These new IDs replace the old baseline for future work; the guide preserves the transition map. All are PLANNED. Each has one focused test with explicit subchecks in the test plan.

Table 1. Project Requirements

ID	Required outcome and measurement	Tests
FWR-01	No protected home/production path, trust, credentials or data; inspect configuration and verify a lab mock boundary.	FWT-01
FWR-02	One host, four VMs, three zones; default-deny flows, restricted administration, console recovery and measured capacity.	FWT-02
FWR-03	Separate AD; three standard users, three groups, one privileged admin; six application allow/deny cases and one access revocation.	FWT-03

ID	Required outcome and measurement	Tests
FWR-04	Windows endpoint and Linux server: supported versions, host firewalls, recorded updates and separate standard/admin rights.	FWT-04
FWR-05	One CA signs one HTTPS application certificate; name/trust/validity work and an untrusted client rejects it.	FWT-05
FWR-06	Lab-only Tailscale reaches only app.ad.lab.test on HTTPS; permitted, denied and revoked access match policy.	FWT-06
FWR-07	Two or three sources show five security events and support one evidence-based denied-access investigation.	FWT-07
FWR-08	One useful PowerShell/Python operation works and repeats safely without unintended changes.	FWT-08
FWR-09	One encrypted off-compute backup restores the agreed application scope; record actual time, data checks and exclusions.	FWT-09
FWR-10	Complete test/evidence traceability, sanitized submission and reviewed GitHub publication; separate engineering and owner UAT.	FWT-10

6. Expected Deliverables

This is the **approved T7 target, not yet created**. T7 needs separate authorization to replace/consolidate the existing eight Office shells. Future location: `docs/deliverables/`; keep filled working records and raw evidence private until reviewed.

Table 2. Expected Deliverables

Deliverable filename	File format	Expected contents
`01-Lab-Environment-and-Architecture.xlsx`	Excel (.xlsx)	Inventory/status, topology, capacity and flows (FWR-01, FWR-02).
`02-Identity-and-Zero-Trust-Implementation.docx`	Word (.docx)	Identities, endpoints, access cases, HTTPS and Tailscale (FWR-03, FWR-04, FWR-05, FWR-06).
`03-Security-Monitoring-and-Testing.xlsx`	Excel (.xlsx)	Events, investigation, tests, automation and restore (FWR-07, FWR-08, FWR-09, FWR-10).
`04-Troubleshooting-and-Lessons.xlsx`	Excel (.xlsx)	Failures, diagnosis, fixes, retests and lessons (FWR-10).
`05-Final-Project-Submission.docx`	Word (.docx)	Results, evidence index, rubric, limits and owner UAT (FWR-10).

7. Implementation Approach

Follow the guide's five phases. Each underlying stage A-L still needs its own approval covering assets, changes, validation and rollback. T6 authorizes documentation only.

Table 3. Implementation Approach

Week	Work and checkpoint
1	Phase 1: readiness, approved host/firewall installation and three zones; verify isolation.
2	Phase 2: AD, users/groups and endpoint baselines. Start Phase 3: HTTPS and six local access cases.
3	Finish Phase 3: Tailscale/revocation. Phase 4: five events, one investigation and automation.
4	Finish Phase 4: backup/restore. Phase 5: ten tests, defects, sanitized submission and owner review.

Allow roughly 8-12 focused hours per week after readiness. This planning estimate excludes delivery/approval delays. Pause dependent work on missing prerequisites; revise dates without weakening safety or adding systems.

8. Success Criteria

All ten tests and their subchecks must pass with expected/actual results and evidence. Denial needs a working control case and matching policy/log observation. Missing checks remain NOT TESTED. Critical isolation, privilege, exposure, disclosure or recovery failures block acceptance. The acceptance criteria separate engineering from owner UAT; CI checks documents only.

Table 4. Success Criteria

Assessment area	Points	Evidence for full credit
Infrastructure and Network Security	25	Four working VMs, three zones, protected management, default deny and isolation.
Identity and Access Controls	25	AD/endpoints, six role cases, revocation, HTTPS and scoped Tailscale.
Security Monitoring and Operations	20	Five events, two or three sources, explained denial and repeatable automation.
Testing and Recovery	20	Complete test records, second observations, successful restore and measured limits.
Documentation and Final Submission	10	Five T7 submissions, traceability, sanitized GitHub evidence and accurate UAT/status.

Total: 100 points. Grade verified outcomes; explain partial/absent evidence. Plans alone earn no implementation credit. Critical safety failures block acceptance regardless of score. Missing T7 files block final submission, not T6 documentation completion.

9. References

- NIST SP 800-207: resource-focused principles; no compliance/certification claim.
- Official technical references: verify installed-version syntax and lawful terms before execution.
- Glossary and task reports: terminology, actual work and evidence cutoffs.